TASK: 27

Insecure Data Storage

&

Sensitive Data Exposure

Gabbani Surendra

What is Insecure data storage?

- Insecure Data Storage occurs when an application stores sensitive information on a device or server without proper security protections such as encryption, secure APIs, or restricted access controls.
- This makes it easy for attackers to extract or view the data if the device is lost, rooted/jailbroken, or accessed using malware, reverse engineering tools, or physical attacks.

Examples:

- Storing passwords in plain text.
- Taking sensitive data in logs / backups.
- Saving tokens in shared preferences / local storage.
- Weak encryption or no encryption.
- Hardcoded credentials in code.

Why It Happens:

- Developers store data locally for user convenience.
- Misconfigured security settings.
- Lack of encryption knowledge.
- Rush to release without testing.
- Improper access permissions on files/databases.

Common Attack Scenarios:

- Device compromised → attacker reads app data.
- Reverse engineering APK → finds hardcoded secrets.
- Malware reading insecure storage.
- Extracting backups from rooted devices.
- Accessing unprotected SQLite databases.

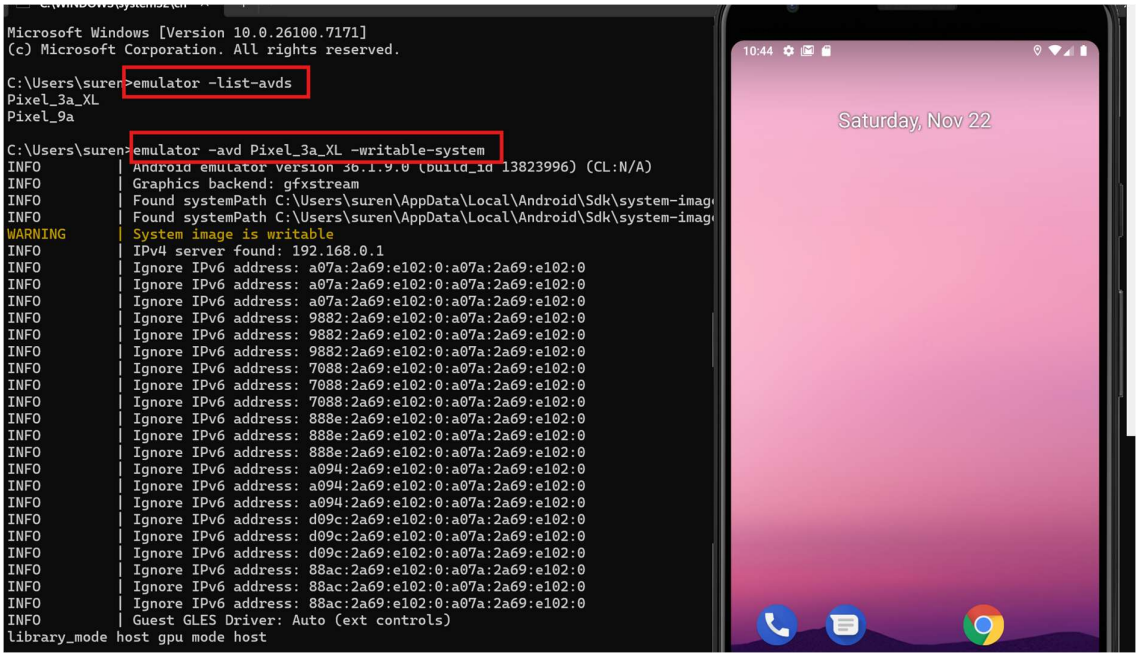
LAB PRACTICAL

Find the Insecure data storage & sensitive data exposure on Lab APK (Insecure shop) User login credentials.

APK:https://github.com/hax0rgb/InsecureShop/releases/download/v1.0/InsecureShop.apk

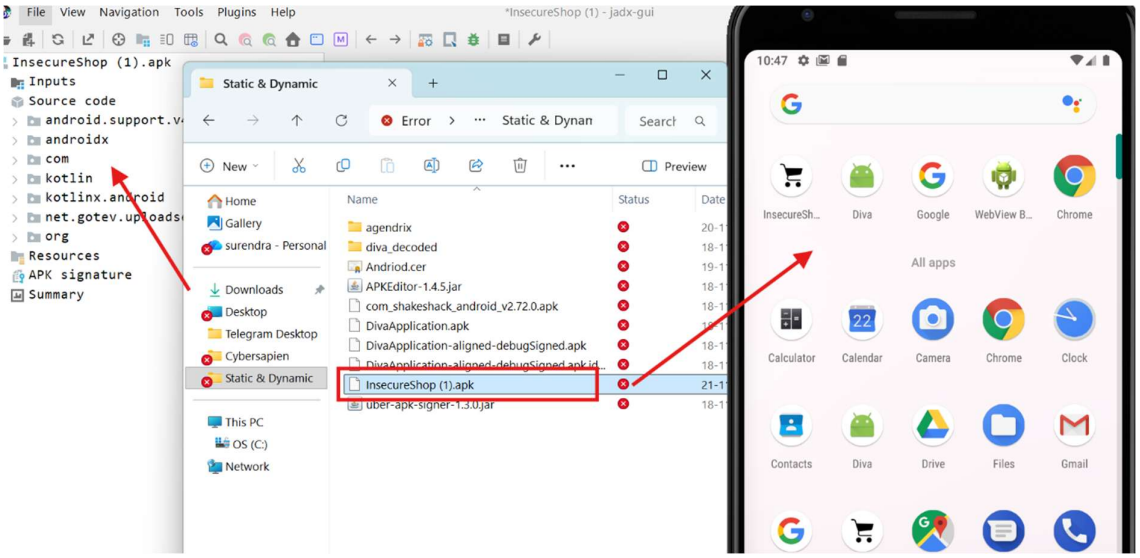
STEP 1:

- Open command prompt and list all the emulators (AVDs).
- Start emulator with writeable system by using commands as below.
- emulator -list-avds.
- emulator -avd Pixel_3a_XL -writable-system.



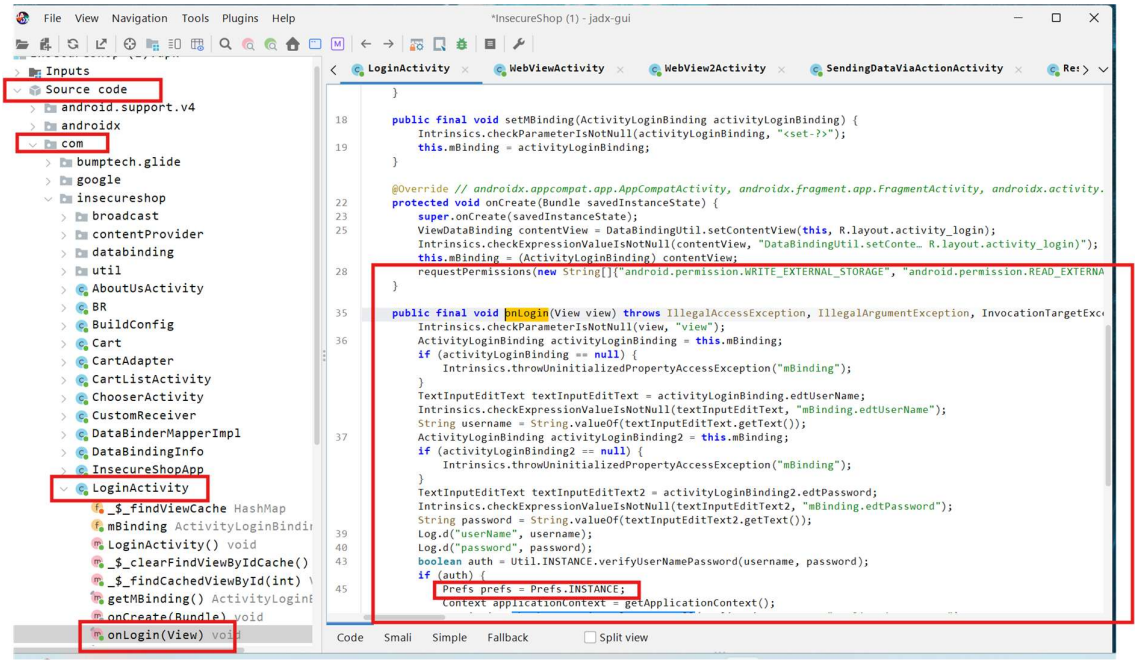
STEP 2:

- Download the APK Application.
- Decompile with the signature.
- Setup the insecure shop APK in both jadx and virtual emulator, by simply dragging into.



STEP 3:

- View the source code of APK completely.
- Go through the folders of highlighted portion.
- Click Onlogin view the source code of login credentials.
- Here the credentials will be saved in Shared Preferences folder XML. Format.



STEP 4:

- Get root access in emulator and enter Android OS terminal shell.
- Move to app's private storage and list files in directory.
- View SharedPreferences folder in XML, read sensitive stored data user credentials below.

```
Microsoft Windows [Version 10.0.26100.7171]
(c) Microsoft Corporation. All rights reserved.

C:\Users\suren>adb root
adbd is already running as root

C:\Users\suren>adb shell
generic_x86_arm:/ # cd data/data/com.insecureshop/
generic_x86_arm:/data/data/com.insecureshop # ls
cache code_cache shared_prefs
generic_x86_arm:/data/data/com.insecureshop # cd shared_prefs
generic_x86_arm:/data/data/com.insecureshop/shared_prefs # ls
Prefs.xml
generic_x86_arm:/data/data/com.insecureshop/shared_prefs # cat Prefs.xml
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
    <string name="password">!ns3csh0p</string>
    <string name="productlist">[{&quot;id&quot;:1,&quot;imageUrl&quot;:&quot;https://images.pexels.com/photos/7974/pexels-photo.
uot;,&quot;name&quot;:&quot;Laptop&quot;,&quot;price&quot;:&quot;80&quot;,&quot;qty&quot;:0,&quot;rating&quot;:1,&quot;url&quot;
t;https://www.insecureshopapp.com&quot;},{&quot;id&quot;:2,&quot;imageUrl&quot;:&quot;https://images.pexels.com/photos/984619/pe
photo-984619.jpeg&quot;,&quot;name&quot;:&quot;Hat&quot;,&quot;price&quot;:&quot;10&quot;,&quot;qty&quot;:0,&quot;rating&quot;:2
t;url&quot;:&quot;https://www.insecureshopapp.com&quot;},{&quot;id&quot;:3,&quot;imageUrl&quot;:&quot;https://images.pexels.com/
s/343720/pexels-photo-343720.jpeg&quot;,&quot;name&quot;:&quot;Sunglasses&quot;,&quot;price&quot;:&quot;10&quot;,&quot;qty&quot;
uot;rating&quot;:4,&quot;url&quot;:&quot;https://www.insecureshopapp.com&quot;},{&quot;id&quot;:4,&quot;imageUrl&quot;:&quot;htt
images.pexels.com/photos/277390/pexels-photo-277390.jpeg&quot;,&quot;name&quot;:&quot;Watch&quot;,&quot;price&quot;:&quot;30&quot
uot;qty&quot;:0,&quot;rating&quot;:4,&quot;url&quot;:&quot;https://www.insecureshopapp.com&quot;},{&quot;id&quot;:5,&quot;imageU
ot;:&quot;https://images.pexels.com/photos/225157/pexels-photo-225157.jpeg&quot;,&quot;name&quot;:&quot;Camera&quot;,&quot;price
;:&quot;40&quot;,&quot;qty&quot;:0,&quot;rating&quot;:2,&quot;url&quot;:&quot;https://www.insecureshopapp.com&quot;},{&quot;id&q
6,&quot;imageUrl&quot;:&quot;https://images.pexels.com/photos/264819/pexels-photo-264819.jpeg&quot;,&quot;name&quot;:&quot;Perfu
uot;,&quot;price&quot;:&quot;10&quot;,&quot;qty&quot;:0,&quot;rating&quot;:2,&quot;url&quot;:&quot;https://www.insecureshopapp.c
ot;},{&quot;id&quot;:7,&quot;imageUrl&quot;:&quot;https://images.pexels.com/photos/532803/pexels-photo-532803.jpeg&quot;,&quot;n
uot;:&quot;Bagpack&quot;,&quot;price&quot;:&quot;20&quot;,&quot;qty&quot;:0,&quot;rating&quot;:2,&quot;url&quot;:&quot;https://w
secureshopapp.com&quot;},{&quot;id&quot;:8,&quot;imageUrl&quot;:&quot;https://images.pexels.com/photos/789812/pexels-photo-789811
g&quot;,&quot;name&quot;:&quot;Jacket&quot;,&quot;price&quot;:&quot;20&quot;,&quot;qty&quot;:0,&quot;rating&quot;:2,&quot;url&qu
quot;https://www.insecureshopapp.com&quot;}]</string>
    <string name="username">shopuser</string>
</map>
```

Real-World Impact:

- Account takeover
- Financial fraud
- Identity theft
- Leakage of company internal data
- Legal and GDPR/DPDP Act penalties

Prevention Methods:

- Encrypt sensitive data at rest (AES-256)
- Avoid storing unnecessary data
- Protect app backups
- Use strong access controls

What is Sensitive Data Exposure?

Sensitive Data Exposure refers to the accidental or intentional leakage of sensitive information due to a lack of proper protection, especially when the data is transmitted, processed, or stored.
It can happen over networks, APIs, cloud storage, or even on user interfaces.

How it occurs?

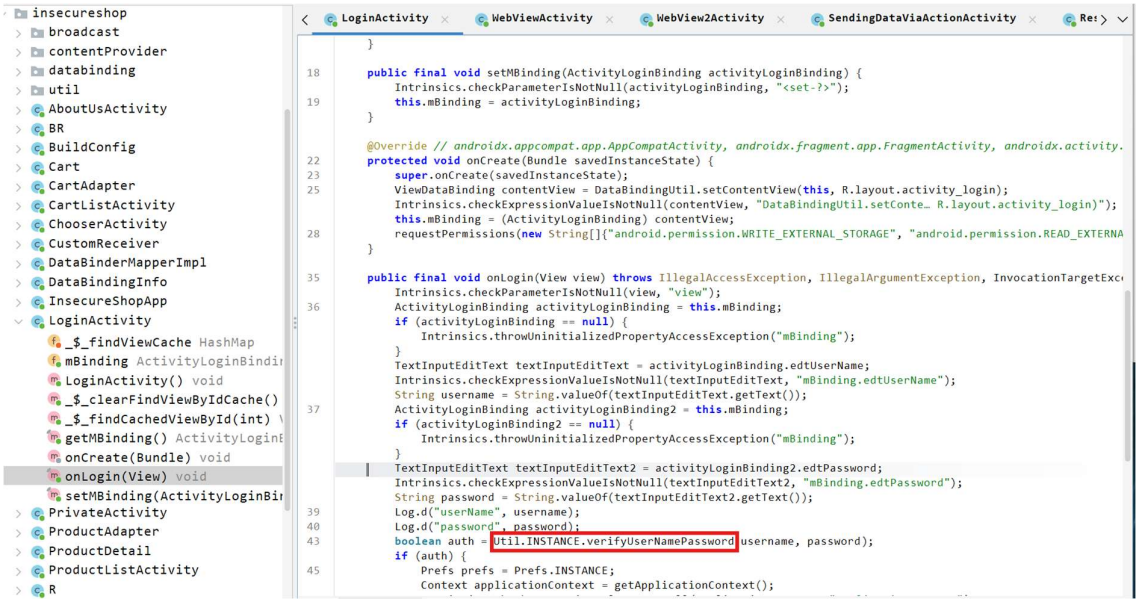
- Sending data over HTTP instead of HTTPS
- Improper or misconfigured TLS/SSL encryption
- Weak or outdated algorithms
- Exposing data in API responses, logs, URLs, or browser storage
- Publicly accessible cloud storage buckets

LAB

Find the Sensitive Data Exposure using lab APK.

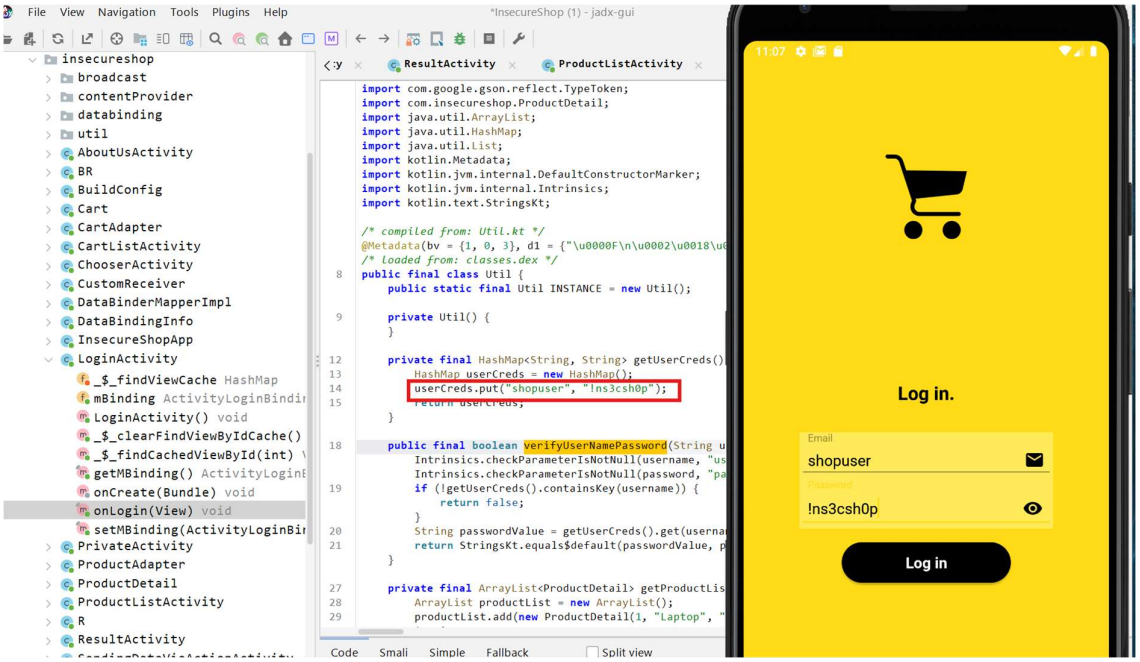
STEP1:

- Data is leaked or exposed here itself in the source code.
- Go through that verify user credentials by double clicking it.
- Insecurely Storing passwords in plain text.



STEP2:

- Here we can retrieve the user credentials data by simply viewing the source code.



Prevention:

- Always use HTTPS/TLS 1.2+.
- Implement certificate pinning.
- Don’t send sensitive data in URL or logs.
- Use strong encryption for data in transit.
- Apply proper API authentication & filtering.
- Validate server certificates.

Impacts of Sensitive Data Exposure

- Sensitive data leaked through APIs or cloud misconfigurations can expose millions of users.
- Leaked personal or confidential data may be used to manipulate users.
- Sensitive business information (source code, designs, API keys) can be stolen and misused.

Conclusion:

- Insecure Data Storage and Sensitive Data Exposure are two critical security issues that can severely compromise the confidentiality, integrity, and privacy of user information.
  While Insecure Data Storage focuses on how sensitive information is protected at rest, Sensitive Data Exposure concerns how data is handled, transmitted, and processed across the entire application lifecycle.
- Both vulnerabilities commonly arise due to weak encryption practices, improper configuration, insecure communication channels, and lack of secure coding standards. Preventing these issues requires adopting strong encryption mechanisms, enforcing HTTPS/TLS, securing local storage, and following best practices such as key management, data minimization, and secure logging.

References:

- https://owasp.org/www-project-mobile-security-testing-guide/
- https://owasp.org/www-project-top-ten/
- https://owasp.org/www-project-mobile-security/

THANK YOU